

HIPAA Compliance Gap Assessment

Radiantlyk Aesthetic — San Jose, CA

Prepared for: Kiem Vukadinovic, NP & Founder • Medical Director: Dr. Aloysius N. Fobi, MD

Scope: EHR / booking platform, staff workflows, patient portal, e-signatures, PHI storage, marketing.

How to read this report

Each row maps to a HIPAA requirement (Privacy Rule 45 CFR §164.500-534, Security Rule §164.302-318, Breach Notification §164.400-414). **Status:** **Met** = evidence exists in the app today, **Partial** = implemented but incomplete, **Gap** = must be built or documented before you are defensible in an audit.

1. Administrative Safeguards (§164.308)

Requirement	Status	What you have / What's missing	Action
Security Officer designation (§164.308(a)(2))	Gap	No named HIPAA Security Officer or Privacy Officer on file.	Appoint Kiem (or delegate) as Security & Privacy Officer in writing. Save signed appointment letter.
Risk analysis (§164.308(a)(1)(ii)(A))	Partial	This document is a gap assessment. A full, dated risk analysis covering all ePHI systems is still required.	Complete an annual written risk analysis; store PDF in a compliance folder and re-review yearly.
Workforce training	Partial	Compliance module exists in-app (staff signs protocols) but no HIPAA-specific onboarding module.	Add a HIPAA 101 protocol to Compliance Admin; require signature on hire and annually.
Sanction policy	Gap	No written policy for staff who violate privacy rules.	Publish a 1-page sanction policy (verbal warning → written → termination → board report).
Access management & unique user IDs	Met	Backend auth + user_roles table (admin/staff) + separate staff logins.	Keep. Review roles quarterly — remove ex-staff same day.
Automatic logoff	Met	useIdleLogout hook signs out staff after 15 min of inactivity.	Keep.
Audit controls (§164.312(b))	Met	phi_access_log + clinical_audit_log + appointment_audit_log tables record view/download/export.	Review logs monthly; export to a dated PDF quarterly for evidence.
Business Associate Agreements (BAAs)	Gap	Required with every vendor touching PHI: Lovable Cloud (database host), any AI provider used for scribe, SMS provider (Twilio/GHL), email provider (Resend), Stripe, Google (if Calendar syncs PHI).	Request & store signed BAA from each vendor. Do NOT send PHI to any vendor without one.
Contingency plan / backups	Partial	Database has automated backups via hosting; no written disaster-recovery plan or restore test.	Write a 1-page DR plan; perform a test restore yearly and log the result.

Requirement	Status	What you have / What's missing	Action
Incident response plan	Gap	No written breach response procedure.	Document who to call, 60-day breach notification timeline (§164.404), and HHS/OCR reporting steps.

2. Physical Safeguards (§164.310)

Requirement	Status	What you have / What's missing	Action
Facility access controls	Partial	Physical clinic access assumed managed; no written policy.	Document who has keys/alarm codes and revocation on termination.
Workstation security	Gap	No written policy for iPad/laptop use, screen lock, or public-Wi-Fi restrictions.	1-page workstation policy: screen lock ≤5 min, full-disk encryption on, no PHI on personal devices.
Device & media disposal	Gap	No documented procedure for wiping decommissioned devices.	Require factory-wipe + signed disposal log for any device that touched PHI.

3. Technical Safeguards (§164.312)

Requirement	Status	What you have / What's missing	Action
Access control & RLS	Met	Row-Level Security enabled on PHI tables (clinical_notes, gfe_records, consents, photos, etc.) scoped by has_role().	Re-run security scan after every schema change.
Encryption in transit	Met	HTTPS on custom domains (bookrka.com) + backend TLS.	Keep. Force HTTPS on any new subdomain.
Encryption at rest	Met	Postgres + Storage encrypted at rest by hosting.	Keep.
Multi-Factor Authentication for staff	Partial	StaffMfa page exists; MFA not enforced for all staff accounts.	Turn MFA to required for every user with the staff/admin role.
Password policy	Partial	Default auth password rules only.	Enforce 12+ chars, block leaked passwords (HaveIBeenPwned option in auth settings).
Audit trail integrity	Met	Audit tables are append-only via RLS; log_phi_access RPC used app-wide.	Do not add UPDATE/DELETE policies on audit tables.
Transmission security — SMS/email	Partial	SMS reminders/consents may transit through Twilio/GHL/Resend.	(a) Get BAAs. (b) Limit PHI in SMS body to first name + appointment time. Never diagnosis/med names in SMS.

Requirement	Status	What you have / What's missing	Action
AI Scribe recordings	Gap	New AI Scribe records audio and generates SOAP notes. Audio + transcript are PHI.	(a) Explicit patient consent before recording (already built — verify shown every visit). (b) BAA with the AI vendor. (c) Delete raw audio after transcript is finalized, or retain in scribe_sessions with RLS + retention policy.

4. Privacy Rule (§164.500-534)

Requirement	Status	What you have / What's missing	Action
Notice of Privacy Practices (NPP)	Gap	No NPP appears to be posted to patients or acknowledged at intake.	Publish NPP on website + intake flow; capture acknowledgment signature (reuse consents infrastructure).
Minimum necessary standard	Met	Role-scoped RLS limits which staff can see which client data.	Review staff role assignments quarterly.
Patient right to access records (§164.524)	Partial	Patient portal shows own chart timeline, receipts, treatment plans.	Add a one-click "Download my complete record" export (PDF/ZIP) in ClientAccount.
Patient right to amend (§164.526)	Gap	No workflow for patient-requested amendments.	Add a simple request form in portal → routes to staff inbox → addendum recorded in clinical_note_addendums.
Accounting of disclosures (§164.528)	Partial	phi_access_log captures internal access; external disclosures (referrals, subpoenas) not tracked.	Add a disclosures table for outside-the-clinic PHI sharing with 6-year retention.
Authorization for marketing	Partial	Newsletter subscribers table + unsubscribe tokens exist.	Ensure marketing emails/SMS only go to patients who explicitly opted in (checkbox, not pre-checked). Store consent timestamp.
Photo/video consent	Met	photo_consent_records + PhotoConsentDialog capture explicit consent.	Keep. Confirm consent required before any social media use.
Annual patient acknowledgement	Met	Mandatory annual acknowledgement checkbox implemented in intake; valid 12 months, re-signed on next appt.	Keep. Audit report of unsigned patients before next visit.

5. Breach Notification Rule (§164.400-414)

Requirement	Status	What you have / What's missing	Action
Breach detection	Partial	Audit logs exist; no active monitoring/alerting.	Add weekly review of phi_access_log for anomalies (bulk exports, unusual hours).

Requirement	Status	What you have / What's missing	Action
60-day notification	Gap	No template or process.	Template letters ready to send: (a) affected patients, (b) HHS OCR (>500 → immediate + media), (c) state AG (CA CMIA).
California CMIA (state law)	Gap	CA adds a 15-business-day patient notification requirement, stricter than federal.	Bake CMIA timing into the incident response plan.

Priority Action Plan — Next 30/60/90 Days

Do this week (blocking risk)

- Sign yourself as Security & Privacy Officer (one-page letter, dated).
- Get signed BAAs from: Lovable Cloud (database host), your AI Scribe provider, Twilio/GHL, Resend/email, Stripe. Do not send PHI where no BAA is in place.
- Enforce MFA for every staff account.
- Confirm AI Scribe consent is displayed and captured on every recorded visit.
- Publish a Notice of Privacy Practices on bookrka.com and add an acknowledgment step to intake.

Within 30 days

- Write & sign: Sanction Policy, Workstation Security Policy, Device Disposal Policy, Incident Response Plan (incl. CA CMIA 15-day & federal 60-day).
- Add HIPAA 101 protocol to Compliance Admin; require signature from every staff member.
- Enable password strength + leaked-password protection in auth settings.
- Restrict SMS/email PHI content to first name + appointment time only.

Within 60-90 days

- Build patient "Download my complete record" export in the portal.
- Build patient amendment request workflow.
- Add external disclosures tracking table (6-year retention).
- Run a disaster-recovery test restore; log the result.
- Schedule annual risk analysis for the same month each year.

Documentation retention

HIPAA requires 6 years retention (from creation or last effective date) for policies, risk analyses, training records, BAAs, audit logs, and breach documentation. California medical records: minimum 7 years after last visit (or age 19 for minors).

This assessment is a compliance planning aid based on the current app codebase and stated workflows. It is not a legal opinion. Have a healthcare attorney review your final policies and BAAs before an audit.